Pr Out STUDIO

プロトタイピングで
ガンガン作って攻めるための、
最低限の身の丈セキュリティ話

第2回 ものづくり医療研究会

2026/11/15（日）13:45〜 ふれあい貸し会議室 秋葉原No53



菅原のびすけ

- プロトタイピングスクール「プロトアウトスタジオ」
- デジタルハリウッド大学大学院 非常勤講師
  - プロダクトプロトタイピング

個人活動

- IoTLT（国内最大のIoTコミュニティ）主催
- Developers Summit 2025 ベストスピーカー 1位
- LINE API Expert / Microsoft MVP / IBM Champion

AIで医療者もアプリが作れる時代ですね

- 受付・順番待ちシステム
- 問診フォーム
- 院内の業務改善アプリ

産院の院長がChatGPTで患者呼び出しシステムを作った



産院のいんちょ (@A_Mochizuki) on X

X (formerly Twitter) / 2026-10-16

Pythonは書けないけど、院内LANから呼べる待合室の呼び出しシステム（@A_Mochizuki さん 2026/10/16）

今日のメッセージ

セキュリティが心配だから作らない、ではなく

「ここは意識してます」と自信を持って言えるから、
ガンガン作れる

今日のアジェンダ

- 1. 集めない
- 2. 持たない
- 3. 分ける
- 4. 身の丈の運用
- 5. まとめ

今日のアジェンダ

- **1. 集めない**
- 2. 持たない
- 3. 分ける
- 4. 身の丈の運用
- 5. まとめ

AIに受付システムを作らせると、とりあえず全部聞いてくる

- 氏名
- 生年月日
- メールアドレス
- 電話番号

予約の時点で、生年月日まで聞かれる



以下の必要項目に入力をお願いします

診療されるご本人のお名前

姓 *
例) 山田

名 *
例) 太郎

セイ *
例) ヤマダ
カナまたはアルファベット

メイ *
例) タロウ
カナまたはアルファベット

生年月日 *
年 月 日

性別 *
男性 女性

電話番号 *
ハイフンなしで入力

メールアドレス *
予約の完了メールなどを受信します
メールアドレスを持っていない
メールアドレスは必須です

郵便番号 *
例) 1234567

住所 *
日本語

ある医療機関のWeb予約フォーム（必須：氏名・フリガナ・生年月日・性別・電話番号・メール・郵便番号・住所）

来院したら、問診票でもまた生年月日を書く

順番を管理するだけなら受付番号で済むかも

- 氏名・生年月日・メール・電話 => **A-023**
- 患者さんとの対応が必要なら、既存の受付システム側で持てないか

受付番号も患者さんと結び付くなら個人情報になり得る

集めない

持っていない情報は漏らせない

その項目、本当に要りますか？

- メールアドレス、氏名、電話番号、要る？
- 住所や生年月日まで取る理由ある？
- そもそもユーザー登録、要る？
- 保存する必要ある？ いつ消す？
- 自由記述じゃなくて選択式にできない？

紙の問診票でも、生年月日とか無駄に聞くのはやめよう

- アプリでも紙でも、書いてもらった情報は持つことになる
- 紙もなくす、置き忘れる、見られる
- => 紙の問診票からも、要らない項目を消す

修学旅行で名簿の入ったリュックを紛失



修学旅行中に教員がリュックサックを紛失　2年生226人全員の個人情報流出の可能性　広島県立の高校で（RCC中国放送） - Yahoo!ニュース

Yahoo!ニュース

紙の名簿もなくすときはなくす 2026/10/20

修学旅行中に名簿の入ったリュックを紛失

県立高校の修学旅行中に、引率の教員が、生徒の名簿などが入った私物のリュックを新横浜駅の付近に置き忘れた。2年生226名分の氏名と保護者の連絡先、108名分の健康調査表（治療中の病気や受診履歴など）が入っていた。

広島県教育委員会 報道提供資料 / 2026年10月20日

出典: 広島県教育委員会 https://www.pref.hiroshima.lg.jp/uploaded/attachment/686187.pdf

フォームを減らすと入力も実装も楽になる

- 入力が減る => 患者さんが楽、入力ミスも減る
- 項目が減る => 実装も保存も削除も楽
- => **セキュリティとUXはトレードオフじゃない**

AIが作ったフォームから、人間が項目を削る



作らない機能を決めることもセキュリティ設計

今日のアジェンダ

- 1. 集めない
- **2. 持たない**
- 3. 分ける
- 4. 身の丈の運用
- 5. まとめ

持たない

毎回生年月日を入れさせたくない

でも、**DBには貯めたくない**

病院の個人PCでサポート詐欺

2026 06/03 wed お知らせ

個人情報漏洩に関するご報告とお詫び

令和8年6月3日

患者様各位

藤田医科大学病院
病院長　今泉 和良

愛知県の藤田医科大学病院で個人情報漏えいの可能性、規定に反して情報を持ち出した個人PCがサポート詐欺に

INTERNET Watch / 2026-06-05



サポート詐欺で発覚 ～ 産婦人科医師が不適切な状態で患者データ保管 | ScanNetSecurity

ScanNetSecurity

患者情報を個人PCに置いていたら、サポート詐欺

看護師の個人PCが遠隔操作された

院内規定に反して個人PCに保存していた患者情報（氏名、生年月日、病名、検査データなど1,365件）が漏えいした可能性。

藤田医科大学病院の発表 / INTERNET Watch / 2026年6月3日

医師の個人PCがサポート詐欺に

研究目的で集めた患者の個人情報が、個人所有のパソコンに保存されていたことが分かった。

近畿大学病院の発表 / ScanNetSecurity / 2024年5月13日

参考: 漏らされったー https://morasaretter.suke.dev/

USBメモリもなくす

患者情報入りのUSBメモリを一時紛失

医師が使っていた、患者の氏名・患者ID・病名・入退院日などを記録したUSBメモリを一時紛失（のちに回収）。

関西医科大学附属病院 / セキュリティ対策Lab / 2026年6月3日公表

2回目からはパスキーでログイン

- パスワードを作らせない
- 使い回しを防ぎやすい
- フィッシングに強い
- パスワード再設定を作らなくていい

参考: Setlogの登録画面

ログインできる ≠ 患者本人

ログイン認証

- パスキー
- Google / Appleログイン

そのアカウントを使っていい人か

本人確認

- 初回に病院で確認
- 患者IDとアカウントを紐付け

医療機関に登録された患者本人か

受付QR＋一時トークンで問診フォームを開く

- 1. 受付で患者さんごとのQRを発行
- 2. スマホで問診フォームを開いて回答
- 3. 回答は問診IDに紐付けて保存
- 4. 患者IDとの対応は既存の患者管理システム側で

QRを持っているだけで本人とは言い切れない（渡し間違い、転送、盗撮）

入力補助だけなら、スマホ側に置く案も（検証途中）

- 生年月日などを Web Crypto API などで暗号化して患者さんのスマホに保存
- => 病院のDBには入力補助用の生年月日が無い
- 共用端末、端末紛失、XSS、鍵の管理はまだ課題

今日のアジェンダ

- 1. 集めない
- 2. 持たない
- **3. 分ける**
- 4. 身の丈の運用
- 5. まとめ

患者DB・問診DB・対応表を分ける

患者DB

- 患者ID
- 氏名
- 生年月日

漏れても問診内容は出ない

問診DB

- 問診ID
- 症状、既往歴
- 暗号化

漏れても氏名は出ない

対応表

- 患者IDと問診IDの対応だけ
- 別の場所に置く

見られる人を絞る

IDを分けただけでは匿名化にはならない

DBだけじゃなく、サーバーや場所、ネットワークも分けておく

- 1. 同じDBの中でテーブルを分ける
- 2. 別のDBに分ける
- 3. 別のサーバーに分ける
- 4. 別のネットワーク・クラウド環境に分ける
- 5. アカウント・アクセス権限を分ける
- 6. 暗号鍵の管理も分ける

分けすぎると運用が大変になるので、身の丈で

分ける

分けるだけじゃダメ

全部見られるアプリが乗っ取られたら、全部取られる

鍵と権限も分ける

- アプリごとに必要なDBにだけアクセスさせる
- 患者情報と問診内容を取るAPIを分ける
- 受付スタッフと医師で見える情報を分ける
- 一括ダウンロードと管理者権限を絞る
- ログやバックアップにも個人情報が残る

集めない・持たない・分ける

漏れても被害が小さくなる設計

今日のアジェンダ

- 1. 集めない
- 2. 持たない
- 3. 分ける
- **4. 身の丈の運用**
- 5. まとめ

「URLを知ってる人だけ」はアクセス制御じゃない

- robots.txt => セキュリティの仕組みじゃない
- noindex => 検索に出にくくするだけ
- => 見せたくないデータには**認証とアクセス制御**

例: ChatGPT の共有リンクの会話が、検索結果に出ていた（2025年8月）

介護・医療の設定ミス

福岡県働きやすい介護職場認証制度事業における個人情報の漏えい事案について - 福岡県庁ホームページ

福岡県庁ホームページ



表示されるべきでない患者一覧が閲覧可能に ～ 大阪公立大学医学部附属病院 | ScanNetSecurity

ScanNetSecurity



ニチイ学館、介護サイトで個人情報漏洩のおそれ―583名分、99名は健康状態・障がい情報を含む|セキュリティニュースのセキュリティ対策Lab

合同会社ロケットボーイズ - セキュリティ 情報漏洩のニュースサイト セキュリティ対策Labの運営とBtoB マーケティング コンサル 支援 / 2026-10-06

設定ミスで「誰でも見られる」状態に

介護サイトの問い合わせデータ

バックアップファイルが2020年5月から2026年9月まで認証なしで取得できる状態だった。健康状態や障がいの情報も。

ニチイ学館 / セキュリティ対策Lab / 2026年10月

介護職場認証の申請ファイル

委託先がファイルの設定を誤り、役員183人分の氏名・生年月日などが閲覧できる状態だった。

福岡県 報道発表 / NHK / 2026年9月29日

地域医療連携ネットワーク

設定の不備で、本来表示されないはずの患者一覧が閲覧できる状態だった。

大阪公立大学医学部附属病院 / ScanNetSecurity / 2024年12月

参考: 漏らされったー https://morasaretter.suke.dev/

Privateリポジトリでも、アカウントが乗っ取られたら見られる

- GitHubにパスキーか二要素認証を設定
- Privateでも APIキーは置かない
- 繋いだAIツールやトークンの権限を見直す

GitHubはパスキーでログインできる



パスキーの概要 - GitHubドキュメント

GitHub Docs

普通の入力フォームが攻撃の入口になる

```
SELECT * FROM reception
WHERE number = '' OR '1'='1'
```

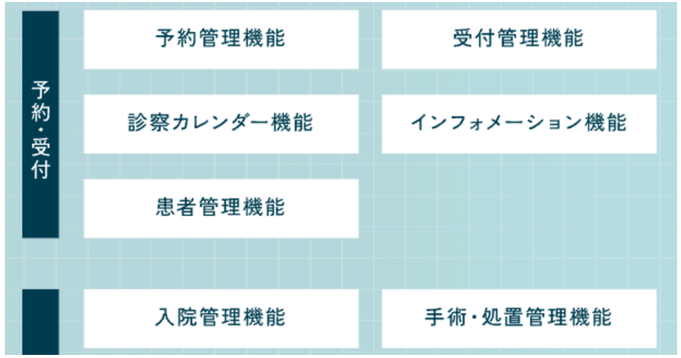
受付番号の欄に ' OR '1'='1 と入れると、全員分が出てくる（架空のDBの例）

予約サイト、患者アプリ、問診データ



ホワイトエッセンス、約105万アカウントの個人情報流出　8月発表の不正アクセス調査で判明

ITmedia NEWS



メドレーの産婦人科向けシステムに不正アクセス、患者の個人情報漏えいか　最大787の医療機関が対象

ITmedia NEWS



資生堂、利用者情報が2515件流出　肌の測定結果など - 日本経済新聞

日本経済新聞 / 2026-11-06

予約サイトや患者アプリも狙われる

予約サイトから基幹システムへ

予約サイトの脆弱性を足がかりに基幹システムへ侵入され、約105万アカウント分の氏名・生年月日などが持ち出された。

ホワイトエッセンス / ITmedia NEWS / 2026年10月

産婦人科向けサービスと患者アプリ

医療機関向けサービスと患者向けアプリが不正アクセスを受けた。対象は最大787の医療機関、人数は調査中。

メドレー @link / ITmedia NEWS / 2026年10月15日

問診データも

肌測定のシステムから、氏名・年齢・問診データ・肌測定結果など2,515件が漏えい。

資生堂 / 日本経済新聞 / 2026年11月6日

出典: ホワイトエッセンスの発表、ITmedia NEWS、日本経済新聞

生成AIとの付き合い方

AIも一律に危ないわけじゃない

契約と設定を見る

学習に使われない ≠ ログが残らない

- ChatGPT Business / Enterprise => 原則、業務データを学習に使わない
- OpenAI API => デフォルトで学習に使わない
- Gemini API => 有料扱いかどうかで条件が変わる
- 試作は**ダミーデータ**で

規約は変わるので、使う前に公式のページで確認する

各社のデータの扱いは公式で確認する



Google AI Studio

aistudio.google.com

作ったあと

作ったあとも脆弱性は出てくる

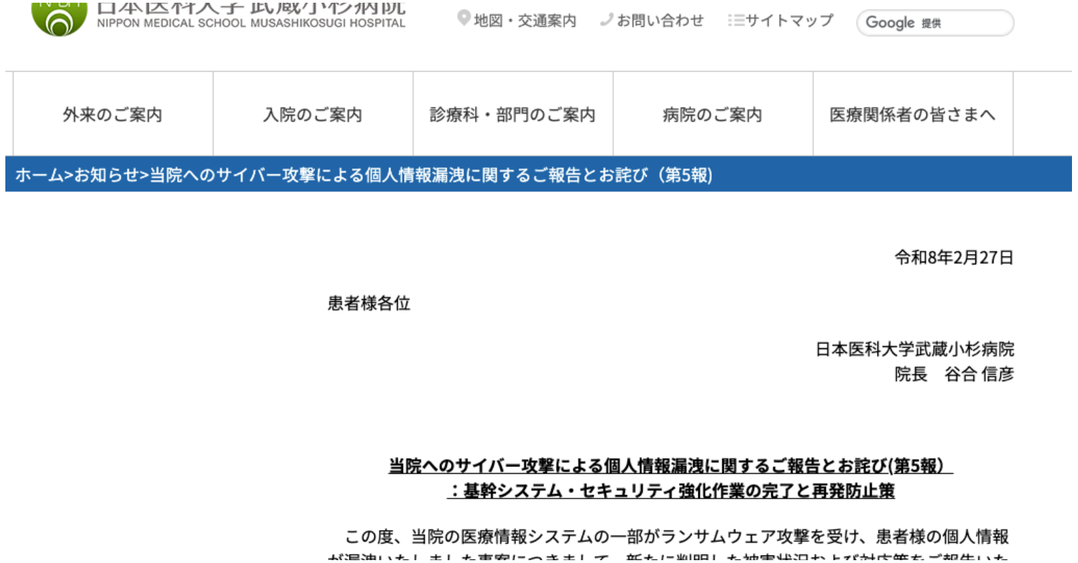
=> 誰が更新する？

医療機器の保守用VPNからランサムウェア



約13万人の患者情報が漏えい ～ 日本医科大学武蔵小杉病院へのランサムウェア攻撃 | ScanNetSecurity

ScanNetSecurity



日本医科大学武蔵小杉病院、ランサムウェア被害の詳細および対策を発表、患者・職員約13万人の個人情報が漏えい

INTERNET Watch / 2026-03-04

保守用の入口や、捨て方からも漏れる

医療機器の保守用VPNから侵入

ナースコール管理サーバーがランサムウェアに感染し、患者約13万人の氏名・住所・生年月日などが漏えい。

日本医科大学武蔵小杉病院 / ScanNetSecurity / 2026年2月〜3月

データを消さずにフリマへ

市立病院の個人データが入ったPOSレジを、委託関連事業者がデータを消さないままフリマアプリに出品した。

気仙沼市立病院 / セキュリティ対策Lab / 2024年8月

参考: 漏らされったー https://morasaretter.suke.dev/

自分のシステムが悪用される側にもなる

- 予約確認や呼び出しのメールを自作の仕組みで送る
- 送信の仕組みやAPIキーを乗っ取られる
- => 病院の名前で不審なメールが届く

メール配信サービス経由で医師の情報が

東邦HD子会社 医師氏名など約8000件が漏洩した可能性 外部メール配信サービスで不正アクセス被害 | ニュース | ミクスOnline

mixonline.jp



東邦HD子会社・eヘルスケア、個人情報8000件漏洩か　医師の氏名やアドレス - 日本経済新聞

日本経済新聞 / 2026-10-23

メール配信サービスからも漏れる

医師のメールアドレス約8000件

メール配信に使っていたサービスが不正アクセスを受け、配信先リストなどが持ち出された可能性。

eヘルスケア / 日本経済新聞・ミクスOnline / 2026年10月23日

今日のメッセージ（再掲）

セキュリティが心配だから作らない、ではなく

「ここは意識してます」と自信を持って言えるから、
ガンガン作れる

まとめ

- 動くアプリと安全なアプリは違う
- **集めない・持たない・分ける**で、漏れても被害が小さい設計に
- 限定公開URLはアクセス制御じゃない
- 作ったあとの更新まで考える

=> 「そもそも集めてない」「分けてある」と自信を持って言えるようにして、ガンガン作ろう